



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2025-66376 Zimbra Collaboration Suite Exploitation Daily Priority

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-31
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2025-66376 Zimbra Collaboration Suite Exploitation Daily Priority - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-31 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2025-66376 Zimbra Collaboration Suite Exploitation Daily Priority

1. Executive Summary

CISA, NSA-partner reporting, and NVD-aligned sources describe continued exploitation of CVE-2025-66376 in Zimbra Collaboration Suite Classic UI. Russian state-supported actors have reportedly used the flaw in phishing operations against Western government and commercial organizations, making unpatched ZCS mailboxes a priority identity and intelligence-loss risk.

Lost Boys Cyber selected this item for the 2026-07-31 UTC daily production run because the reporting indicates active exploitation, common internet exposure, or high operational value to defenders. Source collection favored government, vendor, and reputable security research. Where source depth was thinner than a full exploit teardown, this report labels inference and emphasizes defensive validation.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2025-66376
Product / Component	Enterprise email, collaboration suites, government and commercial mailboxes
Weakness	See source descriptions; defender assessment centers on remotely reachable exploitation path and post-compromise impact.
Severity	High
Affected Versions	Validate against vendor advisory/NVD before operational action.
Fixed Versions	Apply vendor-supported fixed releases or mitigations.
Disclosure / Update Window	Prioritized in daily coverage for 2026-07-31; source set includes material from the last 7 days where available.
Exploitation Status	Reported active exploitation or KEV/campaign relevance.

3. Source Review & Confidence

Source	Contribution	Confidence
CISA AA26-204A Zimbra campaign advisory	Primary government campaign reporting on Russian state-supported targeting of ZCS users.	High
NSA partner press release on Zimbra exploitation	Confirms state-supported exploitation context and continued unpatched risk.	High
NVD CVE-2025-66376	Affected-version and vulnerability-description reference.	High
Qualys ThreatProtect CVE-2025-66376	Defender-facing patch and KEV corroboration.	Medium

Analyst confidence is high for prioritization. Exact exploitability in a given environment depends on version, exposure, compensating controls, and telemetry completeness.

4. Vulnerability Details

CVE-2025-66376 is a stored cross-site scripting vulnerability involving improper sanitization of CSS @import directives in HTML email content. When a victim views malicious content in the vulnerable Classic UI, attacker-controlled JavaScript can run in the webmail session context, enabling mailbox access, message theft, phishing follow-on, and persistence through account-level artifacts.

5. Attack Scenarios

- Internet-facing vulnerable service receives crafted traffic, resulting in unauthorized application behavior and potential code execution or account/session compromise.
- An attacker uses public proof-of-concept knowledge or campaign tradecraft to identify lagging patch windows and pivot from initial access into credential collection or web-shell persistence.
- A managed-service or third-party maintained deployment remains exposed after internal systems are patched, producing a supply-chain blind spot.

6. Threat Landscape & Exploitation Status

Daily selection was driven by exploitation reporting and defender relevance. Treat confirmed vulnerable externally reachable assets as urgent until patched or isolated. For unconfirmed assets, perform asset-owner validation before accepting residual risk.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing vulnerable service	Highest probability of opportunistic scanning, commodity exploitation, and rapid follow-on intrusion.
Internally reachable but privileged workflow	Lower initial exposure but high impact if reached through VPN, SSO, or adjacent compromise.
Third-party managed instance	Ownership ambiguity can delay patching and log retrieval.
Patched and monitored instance	Reduced risk, but verify exploit attempts and post-patch persistence.

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Asset owner	Inventory affected products, confirm versions, and apply vendor fixes or supported mitigations.
High	Network/security engineering	Restrict exposure, enforce WAF/edge controls where applicable, and alert on exploit-path request patterns.
High	SOC/IR	Hunt for pre-patch exploitation and preserve logs covering the disclosure-to-patch window.
Medium	Vendor management	Confirm third-party patch SLAs and evidence of remediation.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Unusual requests to vulnerable endpoint families	Web, WAF, reverse proxy logs	Surface exploitation attempts and scanners.
New child process or file write by web/application service account	EDR, Sysmon, auditd	Identify successful exploitation leading to execution or persistence.
Suspicious outbound traffic from application host	Network, DNS, proxy	Identify beaconing, payload retrieval, or exfiltration.

9.2. Sigma / Detection Rule

```

title: Daily Priority Vulnerability Web Exploitation Follow-On Activity
status: experimental
description: Detects suspicious process creation by web or application service accounts after
exploitation of daily-priority vulnerabilities.
logsource:
  product: windows
  category: process_creation
detection:
  web_parent:
    ParentImage|contains:
      - w3wp.exe
      - httpd.exe
      - nginx.exe
      - php-cgi.exe
      - php-fpm
  suspicious_child:
    Image|endswith:
      - \cmd.exe
      - \powershell.exe
      - \pwsh.exe
      - \curl.exe
      - \wget.exe
  condition: web_parent and suspicious_child
fields:
  - UtcTime
  - Computer
  - ParentImage
  - Image
  - CommandLine
level: high

```

9.3. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("w3wp.exe", "httpd.exe", "nginx.exe", "php-cgi.exe", "php-fpm")
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe", "curl.exe", "wget.exe", "python.exe",
"perl.exe")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName

```

10. Threat Hunting

10.1. Hunt Hypothesis

If exploitation succeeded, vulnerable application servers may show abnormal web request bursts followed by shell execution, web-root file writes, suspicious authentication, or outbound payload retrieval.

10.2. Hunt Query

```
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("w3wp.exe", "httpd.exe", "nginx.exe", "php-cgi.exe", "php-fpm")
| where RemoteUrl has_any ("pastebin", "raw.githubusercontent.com", "gist.githubusercontent.com") or RemotePort
in (4444, 8080, 8443, 9001)
| project Timestamp, DeviceName, InitiatingProcessFileName, RemoteUrl, RemoteIP, RemotePort
```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Vulnerability is remotely reachable or campaign-relevant against exposed application services.
T1059	Command and Scripting Interpreter	Successful exploitation frequently leads to shell or script execution.
T1105	Ingress Tool Transfer	Attackers commonly retrieve second-stage payloads after initial exploitation.
T1505.003	Server Software Component: Web Shell	Web application exploitation can result in web-shell persistence.

12. Validation / Lab Testing

Step	Result
Source triage	Completed from public source material available during the scheduled run.
Exploit reproduction	Not performed in this automation run; no exploit traffic was generated.
Detection QA	Query and Sigma markers embedded and verified during PDF text extraction.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Vulnerability management	Patch or mitigate confirmed affected systems today.
High	SOC	Run the included hunts for the prior 14 days.
High	IR	Preserve web/proxy/EDR logs for vulnerable assets until exploit status is resolved.
Medium	GRC/vendor management	Confirm third-party exposure and contractual notification paths.

14. References

- [1] CISA AA26-204A Zimbra campaign advisory: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-204a>
- [2] NSA partner press release on Zimbra exploitation: <https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4553352/nsa-and-partners-alert-zimbra-collaboration-suite-users-of-a-russian-state-supply/>
- [3] NVD CVE-2025-66376: <https://nvd.nist.gov/vuln/detail/CVE-2025-66376>
- [4] Qualys ThreatProtect CVE-2025-66376: <https://threatprotect.qualys.com/2026/03/19/cisa-added-zimbra-vulnerability-to-its-known-exploited-vulnerabilities-catalog-cve-2025-66376/>